

AIMS for Leadership

An Executive Guide to ISO 42001

INCLUDING

Ten questions every executive and board member should be able to answer about AI governance.

What This Document Is For

This document is written for board members, C-suite executives, and senior leaders who are responsible for, or asked to account for, how their organisation governs artificial intelligence.

It does not assume any prior knowledge of ISO standards or AI governance frameworks. It assumes only that you are responsible for decisions that affect how AI is developed, deployed or overseen in your organisation. It assumes only that you need to understand what the standard requires of you personally.

"By the end of this document you will be able to answer ten questions that every executive and board member should be able to answer about AI governance."

The Ten Questions

- | | |
|-----|--|
| Q1 | What is AI governance and why is ISO/IEC 42001 the standard we should be measured against? |
| Q2 | What is the primary objective of ISO/IEC 42001 and what does it actually require us to build? |
| Q3 | How does this standard differ from ISO 27001 and the security frameworks we already have? |
| Q4 | What does AIMS mean for our organisation and what difference can it actually make to how we operate? |
| Q5 | How will certification impact our market position, client relationships and stakeholder trust? |
| Q6 | What is top management's mandatory role under ISO/IEC 42001 and what does the standard hold them personally accountable for? |
| Q7 | What does our AI policy need to say and who is responsible for keeping it current? |
| Q8 | What AI systems are we running, what could go wrong with them, and do we have a formal process for identifying and managing those risks? |
| Q9 | What resources do we require and what does it actually take to implement ISO/IEC 42001: people,, budget, time and where do we start? |
| Q10 | How does the PDCA cycle drive continuous improvement in our AIMS and how do we know it is working? |

The AI Governance Moment

For most of the last decade, AI governance was a technology concern. It sat in the engineering team, occasionally surfaced in risk committees, and rarely reached board level unless something went visibly wrong.

That has changed. In 2024 and 2025, three forces converged to make AI governance an executive obligation rather than a technical preference.

Regulation

The EU AI Act, the UK AI Safety Institute framework, and sector-specific guidance from financial and healthcare regulators have created enforceable obligations around how AI systems are developed, assessed and monitored. Non-compliance is no longer a theoretical risk.

Liability

As AI systems make or influence consequential decisions in hiring, lending, clinical pathways and customer service. The question of who is accountable when something goes wrong has become legally and commercially material. Courts and regulators are beginning to answer it.

Trust

Clients, partners, insurers and investors are now asking how organisations govern their AI. The organisations that can demonstrate a functioning, auditable AI management system are gaining a measurable advantage in procurement, partnership and capital conversations.

"ISO/IEC 42001 is the international standard that gives organisations a structured, auditable framework for managing AI responsibly. It is what boards will be judged against."

PART 1

Understanding the Standard

What ISO/IEC 42001 is, what it requires,
and how it differs from what you already have.

Q1 What is AI governance and why is ISO/IEC 42001 the standard we should be measured against?

AI governance is the set of policies, processes, roles and controls that determine how an organisation develops, deploys and oversees artificial intelligence. It answers three fundamental questions: what AI are we running, who is responsible for it, and how do we know it is doing what we intended.

Without governance, AI systems operate on assumptions that have never been tested, risks that have never been assessed, and accountability that has never been assigned. The consequences (regulatory, legal, reputational and operational) fall on the organisation and ultimately on its leadership.

Why ISO/IEC 42001?

ISO/IEC 42001 is the first international management system standard specifically designed for artificial intelligence. Published in 2023, it was developed by standards bodies across 60 countries and provides a common language and framework for AI governance that regulators, clients and auditors recognise.

It is not a technical specification for building AI. It is a governance framework for managing AI. That means it belongs as much in the boardroom as in the engineering team.

WHY IT MATTERS FOR LEADERSHIP

When a regulator, client or insurer asks how your organisation governs AI, ISO/IEC 42001 is the framework they are increasingly expecting you to reference. Organisations without it are being asked to explain why.

Q2 What is the primary objective of ISO/IEC 42001 and what does it actually require us to build?

The primary objective of ISO/IEC 42001 is to help organisations establish, implement, maintain and continually improve an AI Management System (an AIMS). Not a policy document. Not a set of principles. A functioning system with defined ownership, active processes and evidence that it works.

What the standard requires you to build:

Scope	A defined boundary for what AI systems and activities your AIMS covers.
Policy	A board-approved AI policy that sets your organisation's position on responsible AI.
Risk Process	A systematic method for identifying, assessing and treating risks across the AI lifecycle.
Controls	38 Annex A controls covering how AI systems are developed, operated and monitored.
Accountability	Formally assigned roles and responsibilities for AI governance at every level.
Review	Regular leadership review of AIMS performance, findings and improvement actions.
Audit	Internal audit capability to assess whether the AIMS is operating as intended.

THE KEY DISTINCTION

ISO/IEC 42001 requires a management system, not a checklist. The difference is that a management system has to be operated, reviewed and improved continuously. Leadership cannot sign it off once and consider it done.

Q3 How does this standard differ from ISO 27001 and the security frameworks we already have?

This is one of the most common questions from organisations that already hold ISO 27001 or operate within established security frameworks. The short answer is that ISO 27001 governs information security: the protection of data and systems. ISO/IEC 42001 governs the behaviour and impact of AI, which is a fundamentally different problem.

How they differ:

	ISO 27001	ISO/IEC 42001
Primary concern	Data and system security	AI behaviour and impact
Core question	Is our data protected?	Is our AI responsible and accountable?
Risk focus	Cyber threats and data breaches	AI errors, bias, harm and misuse
Controls	114 security controls	38 AI-specific controls
Who it affects	IT and security teams primarily	Leadership, operations and AI teams
Regulatory link	GDPR, NIS2, data regulation	EU AI Act, sector AI guidance

FOR ORGANISATIONS WITH ISO 27001

ISO/IEC 42001 is designed to integrate with ISO 27001. The two standards share a common management system structure, so if you already have ISO 27001, implementing 42001 builds on what exists rather than replacing it. Annex D of the standard maps the integration points explicitly.

PART 2

The Business Case

What AIMS means for your organisation
and why certification changes the conversation.

Q4 What does AIMS mean for our organisation and what difference can it actually make to how we operate?

An AI Management System changes three things in practice: visibility, accountability and assurance. Most organisations using AI have limited visibility of what AI systems they are actually running, fragmented accountability for what those systems do, and no systematic way of getting assurance that they are performing as intended. A functioning AIMS closes all three gaps.

Operationally

You know what AI you are running, who owns it, what risks it carries and how it is being monitored. AI decisions become auditable rather than opaque.

Culturally

Responsibility for AI governance moves from being an implied IT concern to an explicit organisational commitment with named owners at every level.

Strategically

You can enter conversations with clients, regulators, partners and insurers with documented evidence of how you govern AI, rather than assurances that have no system behind them.

For leadership specifically

You have a management review process that gives you a structured view of how the AIMS is performing, what risks have been identified, and what actions are in progress. You are not relying on informal updates.

Q5 **How will certification impact our market position, client relationships and stakeholder trust?**

Certification to ISO/IEC 42001 is not yet a universal requirement, but it is becoming a differentiator in sectors where AI is consequential and scrutiny is high. The organisations moving earliest are gaining ground that will become harder to close.

Clients and procurement

Enterprise clients, particularly in financial services, healthcare and the public sector, are adding AI governance requirements to procurement frameworks. Certification provides documented evidence rather than questionnaire responses.

Regulators

Regulators under the EU AI Act and equivalent frameworks are developing audit and conformity assessment processes. Organisations with a certified AIMS are better positioned to demonstrate compliance and engage constructively with oversight bodies.

Insurers

AI liability is an emerging product line. Underwriters are developing criteria for assessing AI governance maturity. A certified AIMS reduces perceived risk and is beginning to affect coverage terms and premiums.

Investors and boards

ESG frameworks are expanding to include AI ethics and governance. Investors with responsible technology mandates are asking how portfolio organisations manage AI risk. Certification is a credible, auditable answer.

"Certification does not just signal that you take AI governance seriously. It proves it with a third-party audit trail that no internal policy document can match."

The Human Story

A Financial Services Firm That Got It Right

A mid-sized financial services organisation operating across three European markets began implementing ISO/IEC 42001 in early 2023, not because a regulator required it, but because their largest institutional client had begun asking detailed questions about AI governance in annual supplier reviews and the answers were not good enough.

The implementation took fourteen months. It required the appointment of an AI governance lead, a full inventory of the seventeen AI systems they were operating across lending, fraud detection and customer service, a formal risk assessment for each system, and the development of an AI policy that the board reviewed and approved.

What they gained:

Client retention	The institutional client renewed a three-year contract and cited the AIMS certification as a material factor in their decision.
Regulatory confidence	When the national financial regulator launched an AI governance review of the sector, the firm was able to respond with documented evidence within two weeks. Competitors took months.
Internal clarity	For the first time, the board had a single view of what AI the organisation was running, what risks each system carried, and who owned each one.
Insurance terms	Their cyber and professional liability insurer reduced premiums by 8% at renewal, citing the AIMS certification as evidence of reduced AI risk exposure.
Competitive position	Two new enterprise clients in the following year cited ISO/IEC 42001 certification in their vendor selection rationale.

"The board went from asking whether AI governance was necessary to being able to prove it was in place."

THE LESSON

ISO/IEC 42001 pays back in risk reduction, client trust and regulatory confidence. Organisations that move early gain ground that competitors cannot quickly close.

PART 3

Accountability

What the standard places on leadership personally
and what your AI policy must contain.

Q6 What is top management's mandatory role under ISO/IEC 42001 and what does the standard hold them personally accountable for?

ISO/IEC 42001 is explicit on this point in a way that many governance standards are not. Clause 5 places a specific set of obligations on top management, not on the AI team, not on the CISO, not on a governance committee. On leadership personally.

What top management must personally do:

Establish the AI policy	The board must approve an AI policy that reflects the organisation's values, risk appetite and commitments on responsible AI. This cannot be delegated to write and ignore.
Ensure integration	AI governance must be integrated into the organisation's business processes, not treated as a parallel compliance exercise run by a separate team.
Ensure resources	Top management must ensure the AIMS has the people, budget and tools it needs to operate. Resource constraints are a leadership decision, not a technical one.
Communicate importance	The standard requires that the importance of AI governance is actively communicated throughout the organisation. Culture comes from the top.
Direct and support	Leaders must direct staff to contribute to AIMS effectiveness and actively support those with governance responsibilities.
Review performance	Top management conducts formal management reviews of the AIMS, not quarterly update emails, but structured reviews with documented outputs and actions. erly update emails, but structured reviews with documented outputs and actions.

WHAT THIS MEANS IN PRACTICE

The standard does not require the CEO to run the AIMS day to day. It requires that leadership takes visible, documented ownership of the framework: approving policy, allocating resources, reviewing performance and ensuring AI governance is treated as a strategic priority rather than a compliance afterthought.

Q7 What does our AI policy need to say and who is responsible for keeping it current?

The AI policy is the foundational document of the AIMS. It is the statement of organisational intent: what the organisation commits to in terms of responsible AI, and the frame within which all AI governance decisions are made. ISO/IEC 42001 requires that top management establishes, implements and maintains it.

What the standard requires the AI policy to contain:

Organisational objectives	A clear statement of the organisation's AI-related objectives and how AI governance supports them.
Commitment to compliance	A commitment to satisfying applicable legal, regulatory and contractual requirements related to AI.
Commitment to improvement	A commitment to continual improvement of the AIMS, not a static document but a living commitment.
Risk appetite	The organisation's position on what level of AI risk is acceptable and how risk is to be managed.
Responsible AI principles	The values the organisation holds in relation to fairness, transparency, accountability and human oversight of AI.
Scope	What AI systems, activities and parts of the organisation the policy covers.

Ownership, Review and the Cost of a Weak Policy

The AI policy must be approved by top management. Not endorsed, not noted. Approved. It must be available to relevant interested parties, which in practice means clients, regulators and auditors should be able to see it or a summary of it on request.

"An AI policy that was written once and never reviewed is not a policy. It is a document that creates liability without providing governance."

Who owns the AI policy:

Top management approves it. An AI governance lead or equivalent typically owns the process of maintaining and reviewing it. Legal, compliance and operational leads contribute to each review cycle. The board sees it at least annually.

What a weak AI policy exposes the organisation to:

Regulatory exposure	A policy that does not address applicable regulation (EU AI Act, sector guidance, data protection) creates a documented gap that regulators can act on.
Audit findings	Certification audits assess the policy against the standard's requirements. A weak policy generates findings that must be remediated before certification is granted.
Client risk	Enterprise clients reviewing AI governance will request the policy. A policy that is vague, outdated or inconsistent with actual practice damages confidence.
Internal drift	Without a clear policy, individual teams make their own AI governance decisions. The result is inconsistency, ungoverned risk and no audit trail.

PART 4

Risk

What AI systems you are running, what could go wrong,
and how the standard requires you to manage it.

Q8 What AI systems are we running, what could go wrong with them, and do we have a formal process for identifying and managing those risks?

Most organisations that have not implemented ISO/IEC 42001 cannot answer the first part of this question with confidence. AI systems accumulate across procurement tools, customer service platforms, fraud detection, HR screening and forecasting models, often without a central inventory or formal risk assessment for any of them.

The standard requires a formal AI risk assessment process that operates across the full lifecycle of each AI system, from initial development or procurement through deployment, operation and eventual decommissioning.

THE BOARD-LEVEL QUESTION

Leadership does not need to understand the technical details of each AI system. Leadership needs to know that a formal inventory exists, that each system has been risk-assessed, and that someone is accountable for each one.

AI Risk Categories: A Board-Level View

The risks associated with AI systems are different in character from conventional technology risks. They are not primarily about systems going down. They are about systems doing the wrong thing, affecting people in ways that were not intended, or creating liability that was never anticipated.

Risk Category	What It Means	Example	Good Mitigation
Operational	AI system performs incorrectly or inconsistently in live use	<i>Fraud detection model generates excessive false positives, blocking legitimate transactions</i>	Regular performance monitoring, defined accuracy thresholds, human override process
Ethical / Bias	AI produces outputs that are unfair, discriminatory or harmful to individuals	<i>Hiring AI screens out qualified candidates from certain demographic groups</i>	Bias testing at design stage, impact assessment, ongoing monitoring of outcomes
Legal / Regulatory	AI use creates compliance exposure under data protection, sector or AI-specific regulation	<i>AI system processes personal data in ways not covered by existing privacy notices</i>	Legal review at design stage, regulatory mapping, documented compliance evidence
Reputational	AI failure or misuse becomes publicly visible and damages trust	<i>Customer service AI produces offensive or misleading responses that reach social media</i>	Human oversight for high-risk interactions, incident response plan, transparency policy
Third-Party	AI systems or models sourced externally introduce risk the organisation has not assessed	<i>Vendor AI model updated without notice, changing behaviour in production systems</i>	Vendor governance requirements, change notification clauses, independent validation
Strategic	AI governance failures affect the organisation's market position or stakeholder relationships	<i>Major client declines renewal citing inability to evidence AI governance practices</i>	AIMS certification, AI policy publication, regular stakeholder communication

PART 5

Implementation

What resources implementation requires
and where to start.

Q9 **What resources do we require and what does it actually take to implement ISO/IEC 42001: people, budget, time and where do we start?**

Implementation scale depends on the size and complexity of the organisation, the number of AI systems in scope, and what governance infrastructure already exists. The ranges below reflect what organisations typically encounter, not worst case, not best case.

People

An AI governance lead or equivalent. This can be an existing role expanded, not necessarily a new hire. Involvement from legal, compliance, IT and operational leads. Executive sponsor at board or C-suite level. ssarily a new hire. Involvement from legal, compliance, IT and operational leads. Executive sponsor at board or C-suite level.

Budget

Implementation consulting and gap assessment: £15k–£40k depending on complexity. Certification audit: £8k–£20k. Internal resource time: typically 0.5–1.5 FTE over the implementation period.

Time

Gap assessment and scoping: 4–8 weeks. Policy and process development: 3–5 months. Control implementation and evidence gathering: 3–6 months. Certification audit: 1–2 months. Total: 12–18 months for most organisations.

Where to start

Commission a gap assessment against ISO/IEC 42001 before anything else. It tells you what you already have, what you are missing, and where the highest-priority gaps are. Without it you are building without a foundation.

WHAT ORGANISATIONS TYPICALLY UNDERESTIMATE

The time required to build an accurate AI system inventory. Most organisations discover significantly more AI systems in scope than they expected, including third-party tools with embedded AI components that were never assessed as AI systems.

PART 6

Performance

How the PDCA cycle drives continuous improvement
and how leadership knows it is working.

Q10 How does the PDCA cycle drive continuous improvement in our AIMS and how do we know it is working?

ISO/IEC 42001 is built on the Plan-Do-Check-Act cycle, the same operating logic that underpins ISO 27001, ISO 9001 and every other major management system standard. It is not a one-time implementation. It is a continuous operating loop.

PLAN	Clauses 4, 5, 6, 7 Understand the organisation's context. Set the AI policy. Assess risks. Define objectives. Assign roles. Build the governance infrastructure.
DO	Clause 8 Operate the AIMS. Implement risk treatment plans. Conduct AI impact assessments. Apply Annex A controls to AI systems in scope.
CHECK	Clause 9 Monitor and measure AIMS performance. Conduct internal audits. Hold management reviews. Evaluate whether objectives are being met.
ACT	Clause 10 Address nonconformities. Implement corrective actions. Drive continual improvement. Update the AIMS based on what the Check phase found.

How leadership gets assurance:

The primary assurance mechanism for leadership is the management review, a structured documented review of AIMS performance conducted at planned intervals. The standard specifies what inputs the review must consider: audit results, performance metrics, nonconformities, risk changes, and feedback from interested parties.

The Six Signs Your AIMS Is Working

A functioning AIMS is not invisible. Leadership should be able to observe these six indicators. If any are absent, the system has a gap that needs attention.

01	You know what AI you are running A current, maintained inventory of AI systems exists. Every system has a named owner, a defined scope and a completed risk assessment.
02	Your AI policy is current and approved The policy has been reviewed within the last twelve months, reflects the current regulatory environment, and carries a board approval date.
03	Risks are being managed, not just logged Risk treatment plans exist for identified AI risks and the actions in those plans are being executed and tracked.
04	Internal audits are producing findings Your internal audit programme is operating, findings are being documented, and corrective actions are being implemented and closed.
05	Management reviews are happening Structured management reviews are being conducted at planned intervals with documented inputs, outputs and action owners.
06	Improvement is visible over time The AIMS is getting better. Risks are being reduced, controls are maturing, and the organisation's ability to govern AI is measurably stronger than it was twelve months ago.

What Leadership Should Do This Quarter

Understanding ISO/IEC 42001 is the starting point. The three actions below turn that understanding into progress. Each is specific, achievable within a quarter, and builds directly on what this document has covered.

Action 1

Commission a gap assessment

Engage an ISO/IEC 42001 specialist to assess your organisation's current AI governance practices against the standard's requirements. A gap assessment gives you a precise picture of where you stand, what you already have that counts, and where the highest-priority gaps are. Without it, every other decision is made in the dark. Deliverable: A documented gap assessment report with prioritised findings.

Action 2

Appoint an AI governance lead

Identify and formally appoint the person who owns AI governance in your organisation. This does not need to be a new hire. It needs to be a named individual with clear authority, board-level access, and accountability for AIMS implementation progress. Deliverable: A named AI governance lead with a defined mandate.

Action 3

Schedule an AI policy review

If an AI policy exists, schedule a leadership review of it against the requirements in this document. If one does not exist, commission its development as the first formal output of your AIMS implementation. The policy is the foundation everything else is built on. Deliverable: A reviewed or newly drafted AI policy approved by top management.

The AIMS Simplified Series

This document is part of a series designed to make ISO/IEC 42001 accessible and actionable for every audience that needs to engage with it.

AIMS Simplified

The practitioner guide

115 pages. Covers every clause, all 38 Annex A controls, Annexes C and D in full, real-world examples throughout, and a visual summary of the complete standard. Written for GRC professionals, compliance managers and AI governance leads implementing the standard inside an organisation.

AIMS for Leadership

This document

An executive guide to AI governance. Ten questions every board member and executive should be able to answer. Written for leadership teams who need to understand what the standard requires of them personally.

AIMS Gap Assessment Tool

The gap assessment tool

A structured workbook mapping every clause and every Annex A control to assessment questions, evidence requirements and a maturity rating. Designed for organisations assessing where they stand before or during implementation.

Auditing AIMS

The auditor's guide

Written for internal auditors. Covers what to look for, what evidence to request, and how to classify findings across each clause and control.

"Every organisation using AI needs governance. Every governance team needs these tools."